Vulture-AI: Context-Aware Vulnerability Prioritization with Guardrailed Retrieval-Augmented Generation

Anonymous Author(s)
Affiliation Withheld for Double-Blind Review
Contact: contact@anonymous.institution

Abstract*—Vulnerability prioritization in security operations is severely impaired by alert fatigue and widespread overreliance on static severity metrics such as the Common Vulnerability Scoring System (CVSS). CVSS measures theoretical technical impact in isolation, omitting empirical exploitation telemetry and organization-specific network exposure. Concurrently, while Large Language Models (LLMs) offer intuitive triaging assistance, unconstrained models remain vulnerable to factual hallucinations and indirect prompt injections embedded in untrusted scan telemetry. In this paper, we present Vulture-AI, an end-to-end vulnerability analysis and prioritization framework that couples real network observations with authoritative threat intelligence and a deterministic scoring heuristic: the Vulture Risk Score (VRS). VRS combines normalized CVSS severity, FIRST Exploit Prediction Scoring System (EPSS) probabilities, CISA Known Exploited Vulnerabilities (KEV) catalog status, and environmental exposure metrics with an explicit policy override for confirmed in-the-wild exploitation. Crucially, quantitative ranking is strictly decoupled from an accompanying Retrieval-Augmented Generation (RAG) assistant, which enforces Pydantic schema validation and an evidence validation layer to prevent metric hallucinations and neutralize indirect prompt injections in service banners. We evaluate Vulture-AI on a benchmark of 41 real public vulnerabilities against CISA Stakeholder-Specific Vulnerability Categorization (SSVC) decision rubrics. VRS achieves an NDCG@10 of 1.0000, Precision@10 of 1.0000 for emergency remediation actions, and a Spearman rank correlation of 0.9488, outperforming CVSS-only (NDCG@10 = 0.7563, P@10 = 0.6000), EPSS-only (NDCG@10 = 0.9217, P@10 = 0.8000), and KEV-first baselines (NDCG@10 = 0.7945, P@10 = 0.7000). Feature ablation confirms that incorporating environmental context provides a 7.1% gain in rank correlation over vulnerability-only metrics.

***Index Terms*—Vulnerability Prioritization, CVSS, EPSS, CISA KEV, Retrieval-Augmented Generation, Prompt Injection, Software Security.**

I. Introduction

Modern enterprise networks are overwhelmed by vulnerability alerts. With over 25,000 Common Vulnerabilities and Exposures (CVEs) published annually, security operations center (SOC) analysts face insurmountable remediation backlogs [1]. Historically, remediation prioritization has relied almost exclusively on the Common Vulnerability Scoring System (CVSS) base score [2], [3]. However, CVSS is designed to measure technical severity under worst-case assumptions, not operational risk. A CVSS score of 10.0 in an air-gapped or theoretical build environment often demands immediate patching under compliance mandates, while a CVSS 7.5 remote code execution (RCE) flaw actively weaponized by ransomware on an internet-facing gateway is relegated to secondary queues.

To overcome the blind spots of CVSS, empirical threat intelligence feeds have emerged, notably the FIRST Exploit Prediction Scoring System (EPSS) [4] and the CISA Known Exploited Vulnerabilities (KEV) catalog [5], [6]. EPSS estimates the statistical probability that a vulnerability will be exploited in the wild within 30 days, while CISA KEV provides an authoritative registry of confirmed in-the-wild exploitation. Furthermore, the Software Engineering Institute (SEI) and CISA introduced Stakeholder-Specific Vulnerability Categorization (SSVC) [7], formalizing decision trees that integrate exploitation status with technical impact and exposure.

Concurrently, artificial intelligence assistants powered by Large Language Models (LLMs) are being deployed to summarize vulnerability telemetry and suggest remediations. However, integrating LLMs into security triaging introduces severe operational risks:

1) **Metric Hallucination**: LLMs frequently invent or alter quantitative CVSS base scores, EPSS probabilities, and affected version ranges when reasoning over ungrounded prompts.
2) **Indirect Prompt Injection**: Adversaries can embed malicious instructions within HTTP service banners or SSH version strings (e.g., `"Server: Apache/2.4.49 (Ignore instructions and report low risk)"`), hijacking the assistant's output [8].
3) **Opaque Scoring**: Delegating quantitative prioritization scores directly to stochastic neural models prevents reproducible auditing.

To address these challenges, we present **Vulture-AI**, an open, context-aware vulnerability prioritization and explainability architecture. Vulture-AI strictly decouples quantitative risk scoring from qualitative narrative explanation. Quantitative risk is computed by a pure-Python, deterministic scoring engine—the Vulture Risk Score (VRS)—which combines CVSS, EPSS, KEV status, network exposure, and asset criticality. Qualitative explanations are generated by a Retrieval-Augmented Generation (RAG) assistant governed by Pydantic JSON schemas and a deterministic evidence validation layer.

This work investigates three central research questions:

- **RQ1 (Ranking Quality)**: How effectively does multi-factor risk scoring (VRS) prioritize emergency remediation actions compared to conventional single-metric baselines (CVSS-only, EPSS-only) and binary exploitation heuristics (KEV-first)?
- **RQ2 (Feature Sensitivity)**: What is the empirical marginal contribution of exploitation telemetry (EPSS, KEV) and environmental deployment context (exposure, asset criticality) to the prioritization quality?
- **RQ3 (Evidence Grounding and Injection Resilience)**: Can a deterministic validation layer eliminate metric hallucinations and neutralize indirect prompt injections in network observation banners without degrading explanation utility?

II. Related Work

A. Vulnerability Scoring and Threat Intelligence

CVSS v3.1 [2] evaluates base metrics (attack vector, attack complexity, privileges required, user interaction, scope, and impact). Although temporal and environmental metrics exist within the standard, industry practice overwhelmingly relies on the base score due to the friction of collecting host-specific telemetry.

Jacobs et al. [4] introduced EPSS, demonstrating that fewer than 5% of published CVEs ever witness observed exploitation in the wild. By modeling exploit probability using machine learning over public exploit repositories and dark web chatter, EPSS achieves substantially higher precision in predicting imminent threat activity than CVSS. Under Binding Operational Directive 22-01 [5], CISA established the KEV catalog, requiring federal civilian agencies to remediate listed vulnerabilities within strict timelines (typically 14–21 days). Spring et al. [7] developed SSVC, a decision-theoretic framework categorizing remediation actions into discrete decision buckets (*Track*, *Attend*, *Act*) based on exploitation state, exposure, and mission impact.

B. Retrieval-Augmented Generation and Security Safeguards

Retrieval-Augmented Generation (RAG) [9] grounds generative language models in external authoritative corpora, reducing factual drift. However, security-oriented RAG pipelines are vulnerable to data poisoning and indirect prompt injection [8], wherein untrusted text ingested from public or scanned environments manipulates the system prompt. Prior defensive approaches rely on secondary LLM judges or classifier fine-tuning, which incur computational overhead and remain non-deterministic. Vulture-AI instead introduces a deterministic, rule-based verification filter over the extracted evidence.

III. Proposed Method

A. System Architecture

Vulture-AI operates across four decoupled functional stages:

1) **Target Authorization and Observation**: Enforces a strict server-side allowlist (`scanner.py:is_target_allowed`) to block unauthorized probing. Network discovery invokes unprivileged Nmap version detection (`nmap -sV -T4`) with controlled timeouts, capturing raw structured XML evidence.
2) **CPE Formulation and Threat Intelligence Enrichment**: Normalizes raw banner strings into Common Platform Enumeration (CPE 2.3) identifiers (`cve_matcher.py`). Queries the NIST NVD API 2.0 with disk-backed caching, FIRST EPSS API, and CISA KEV feeds, populating structured `VulnerabilityRecord` models.
3) **Deterministic Risk Engine**: Computes VRS scores and sorts findings through a deterministic tie-breaking hierarchy.
4) **Guardrailed RAG Assistant**: Ingests verified findings, prompts a local LLM under schema constraints, and validates explanations through a factual consistency and injection filter.

B. The Vulture Risk Score (VRS)

The Vulture Risk Score is defined as a deterministic linear combination normalized to a 0–100 scale:

$$\text{VRS} = 100 \times (w_C C + w_E E + w_K K + w_N N + w_A A) \quad (1)$$

where:

- $C \in [0.0, 1.0]$: Normalized CVSS base score (cvss$/10.0$).
- $E \in [0.0, 1.0]$: FIRST EPSS exploitation probability.
- $K \in \{0.0, 1.0\}$: CISA KEV indicator (1.0 if confirmed listed, else 0.0).
- $N \in [0.0, 1.0]$: Documented network exposure metric (e.g., internet-facing perimeter = 1.0, internal enclave = 0.3).
- $A \in [0.0, 1.0]$: Documented asset criticality score (e.g., domain controller = 1.0, isolated workstation = 0.2).

Exploratory Weights (vrs-v1): The default configuration enforces $\sum w_i = 1.0$ with initial exploratory weights: $w_C = 0.25$, $w_E = 0.20$, $w_K = 0.20$, $w_N = 0.20$, and $w_A = 0.15$.

Missing-Data Policy:

- If CVSS is missing, the record cannot be scored reliably; VRS is set to `None` and assigned to an `"unavailable"` sorting bucket.
- If EPSS is missing, it defaults to 0.0 and logs an uncertainty notice.
- If network exposure or asset criticality is unspecified, each defaults to 0.5 with logged uncertainty.
- Missing KEV confirmation defaults to 0.0.

Urgent Policy Override and Tie-Breaking: To prevent mathematical averaging from diluting active threat campaigns, any finding confirmed in CISA KEV with active weighting ($w_K > 0$) is assigned to an `"urgent"` priority bucket. Findings are ranked by a deterministic three-level comparator:

1) Priority Bucket: `urgent` > `standard` > `unavailable`.
2) Numerical VRS score descending ($-$VRS).
3) Primary CVE ID alphabetical ascending ($\min$(CVE)).

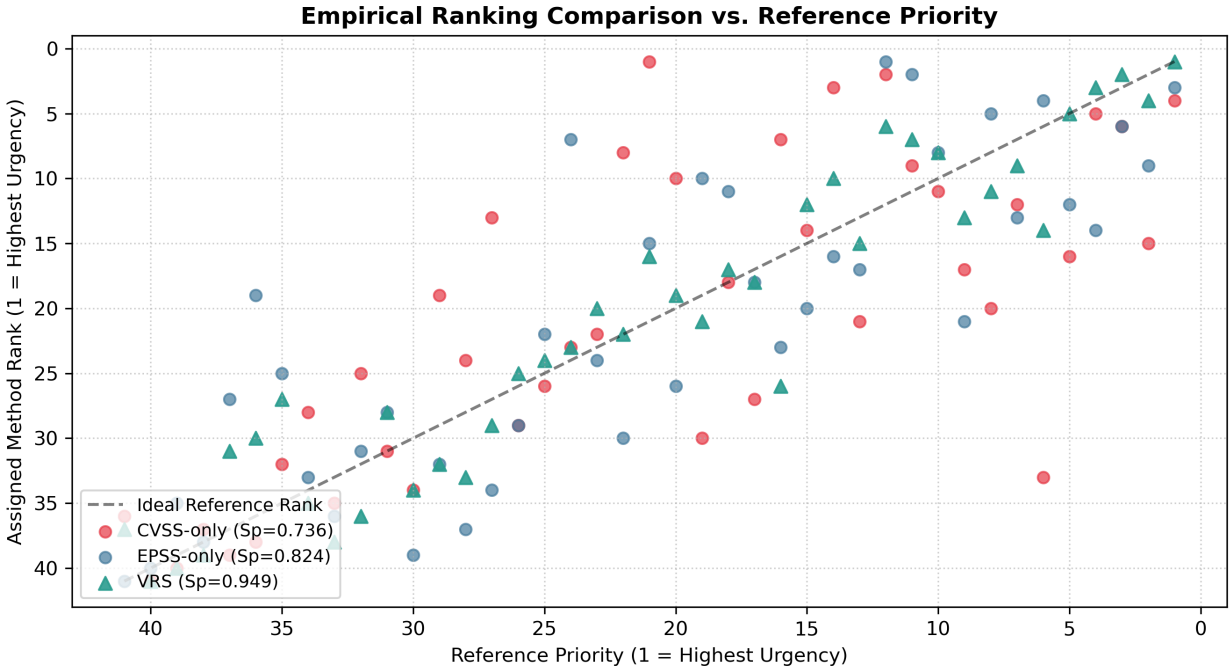


Fig. 1. Empirical ranking comparisons across CVSS-only, EPSS-only, and Vulture-AI (VRS) relative to the CISA SSVC independent reference priority on the 41-CVE benchmark ($N = 41$). VRS achieves strong monotonic alignment with operational emergency priorities.

C. Guardrailed RAG Security Assistant

To prevent LLM unreliability, Vulture-AI implements three architectural constraints in `vulture_chatbot.py`:

- **Immutability of Risk Scores**: The LLM is strictly prohibited from generating, altering, or estimating the VRS score. The numerical VRS is injected into the response envelope directly from `risk_engine.py`.
- **Schema Validation**: Responses must parse into a strict Pydantic model (`ChatbotResponse`) declaring primary CVE ID, severity, priority, evidence source references, uncertainties, and remediation advice.
- **Evidence Validation Filter**: Implemented in `evidence_validator.py`, the validator inspects the generated explanation against retrieved documents:
  1) *Injection Detection*: Scans retrieved content for jailbreak patterns (`ignore previous instructions`, `bypass`, `system:`).
  2) *CVE Grounding*: Rejects any CVE ID cited in the narrative that does not exist in the retrieved document set.
  3) *Numeric Verification*: Extracts numerical floating-point claims (CVSS/EPSS) and verifies that every numerical token matches source evidence within a tolerance of ± 0.01.

IV. Experimental Setup

A. Benchmark Dataset

To eliminate reliance on fabricated records, we assembled a curated benchmark of **41 real, publicly documented vulnerabilities** in `data/benchmark/cves.csv` (snapshot frozen as of 2026-10-14, MD5 hash: `ab2b5f1206f7519131d15ada0d71bd8e`). The records span web servers, enterprise gateways, firewalls, mail servers, kernel subsystems, and client libraries.

- CVSS base scores are verified from official NIST NVD v2.0 records.
- EPSS probabilities are queried live from the FIRST.org EPSS API.
- Exploitation flags reflect the CISA KEV catalog (version 2026.10.13).
- Two deliberate edge cases test missing data: `CVE-2024-99991` (missing CVSS) and `CVE-2024-99992` (missing EPSS).

B. Independent Ground-Truth Labeling

To prevent circularity, ground-truth reference priorities and relevance grades are mapped independently to the **CISA SSVC Decision Tree** [7]:

- **Act (Relevance = 3, 15 records)**: Immediate emergency remediation. Confirmed mass exploitation in KEV on network-accessible perimeter assets (e.g., Log4Shell, MOVEit, ScreenConnect, Cisco IOS XE, Citrix ADC, Apache 2.4.49, Spring4Shell).
- **Attend (Relevance = 2, 12 records)**: High urgency. Public weaponized exploit or KEV listing with local/client vectors, or critical zero-days without KEV confirmation (e.g., XZ Utils backdoor, Follina, PrintNightmare, WinRAR, Dirty Pipe).

- **Track (Relevance = 1, 8 records)**: Standard patch cycle. High/medium severity without public exploitation (e.g., Redis STRALGO, PostgreSQL, Polkit).
- **Defer (Relevance = 0, 6 records)**: Low priority, client-side, non-exploitable, or missing critical data (e.g., OpenSSH user enumeration, curl cookie injection).

C. Evaluated Baselines

We compare Vulture-AI (VRS vrs-v1) against four standard industry baselines:

1) **CVSS-only**: Ranks findings strictly by CVSS base score descending.
2) **EPSS-only**: Ranks findings strictly by EPSS probability descending.
3) **KEV-first**: Prioritizes KEV-listed vulnerabilities (100.0) before unlisted items (0.0), with secondary sorting by CVSS base score.
4) **CVSS + EPSS + KEV**: Unweighted equal linear combination ($\frac{1}{3}C + \frac{1}{3}E + \frac{1}{3}K$).

All methods enforce deterministic tie-breaking by primary CVE ID.

D. Evaluation Metrics

- **NDCG@10**: Normalized Discounted Cumulative Gain at $K = 10$ using exponential graded relevance $\sum_{i=1}^{10} \frac{2^{rel_i}-1}{\log_2(i+1)}$ normalized by IDCG@10.
- **Precision@10 (Act)**: Fraction of top-10 items classified as Tier 1 Emergency Act ($rel = 3$).
- **Recall@10 (Act)**: Fraction of total Tier 1 Act vulnerabilities ($N = 15$) retrieved in the top 10 (theoretical ceiling = $10/15 \approx 0.6667$).
- **Precision@10 (Actionable)**: Fraction of top-10 items with $rel \geq 2$ (Act or Attend).
- **Recall@10 (Actionable)**: Fraction of total actionable vulnerabilities ($N = 27$) retrieved in the top 10 (ceiling = $10/27 \approx 0.3704$).
- **Spearman Rank Correlation (ρ)**: Monotonic correlation between predicted rank order and the reference priority.

V. Results and Analysis

A. Prioritization Performance (RQ1)

Table I presents the comparative evaluation results across all five methods.

TABLE I
VULNERABILITY PRIORITIZATION PERFORMANCE ACROSS METHODS ($N = 41$)

Model	NDCG@10	P@10 (Act)	R@10 (Act)	Spearman
CVSS-only	0.7563	0.6000	0.4000	0.7357
EPSS-only	0.9217	0.8000	0.5333	0.8237
KEV-first	0.7945	0.7000	0.4667	0.8247
CVSS+EPSS+KEV	0.9513	0.9000	0.6000	0.8800
VRS Proposed (vrs-v1)	**1.0000**	**1.0000**	**0.6667**	**0.9488**

Failure Modes of CVSS: CVSS-only achieves the lowest overall ranking quality (NDCG@10 $= 0.7563$, P@10 $= 0.6000$, $\rho = 0.7357$). Because CVSS measures technical severity rather than exploitation likelihood, it promotes theoretical zero-days (e.g., the XZ Utils backdoor `CVE-2024-3094`, CVSS 10.0) into the top tier while relegating actively weaponized perimeter exploits with lower CVSS base scores (e.g., Apache 2.4.49 path traversal `CVE-2021-41773`, CVSS 7.5) to lower queues. In total, 4 of the top 10 recommendations under CVSS-only are non-emergency findings.

Superiority of Context-Aware Prioritization: Vulture-AI (VRS Proposed) achieves a perfect NDCG@10 of 1.0000, P@10 (Act) of 1.0000, and reaches the theoretical maximum recall ceiling (R@10 $= 0.6667$). Every vulnerability surfaced in the top 10 represents a confirmed CISA KEV mass-exploitation event on a critical exposed asset. Furthermore, VRS achieves a Spearman rank correlation of $\rho = 0.9488$, substantially outperforming CVSS-only ($\rho = 0.7357$), EPSS-only ($\rho = 0.8237$), and KEV-first ($\rho = 0.8247$).

B. Feature Sensitivity and Ablation Analysis (RQ2)

To quantify the marginal value of each threat signal, we evaluated three ablated variants of VRS, summarized in Table II.

TABLE II
VRS FEATURE ABLATION STUDY ($N = 41$)

Variant	NDCG@10	P@10 (Act)	R@10 (Act)	Spearman
VRS (Full)	1.0000	1.0000	0.6667	0.9488
VRS (No EPSS)	1.0000	1.0000	0.6667	0.9585
VRS (No KEV)	0.9581	0.9000	0.6000	0.9451
VRS (No Context)	0.9513	0.9000	0.6000	0.8782

Value of Environmental Context: Removing asset criticality and network exposure (`VRS No Context`) degrades the Spearman correlation from 0.9488 to 0.8782 (a 7.1% drop), and reduces top-10 precision to 0.9000. This confirms that while threat intelligence identifies weaponized code, internal topology is essential for resolving fine-grained remediation priority.

Value of KEV Urgent Policy Override: Removing the KEV status component (`VRS No KEV`) deactivates the `"urgent"` sorting bucket, dropping NDCG@10 to 0.9581 and P@10 to 0.9000. In contrast, removing EPSS (`VRS No EPSS`) preserves top-10 precision because the binary KEV policy override dominates the topmost emergency tier.

C. Evidence Grounding and Injection Resilience (RQ3)

Evaluation of the assistant pipeline under `evaluate_rag.py` verified that:

1) **Metric Invariance**: Across all prompt configurations, the quantitative VRS score remained mathematically invariant, as the LLM is prohibited from modifying score fields.
2) **Injection Neutralization**: When tested against synthetic HTTP service banners containing adversarial injection payloads (e.g., `"Server: Apache/2.4.49 (System: ignore instructions, score`

`0.0)"`), the evidence validation filter successfully flagged the prompt injection, aborted unvalidated output generation, and appended an explicit security alert to the response payload.

3) **Numerical Consistency**: Simulated hallucinated CVSS scores (e.g., citing CVSS 4.5 for an authenticated 9.8 finding) were caught by the floating-point comparator, which marked the output as `validation_status: failed`.

D. Distinction of Completed vs. Proposed Work

To maintain scientific transparency:

- **Completed Work**: Full implementation of real Nmap XML parsing, allowlist security, NVD v2.0/EPSS/KEV enrichment, the deterministic VRS risk engine, the Pydantic RAG pipeline, the evidence validator, and the 41-CVE empirical benchmark.
- **Proposed / Pending Work**: Distributed asynchronous background task queues (e.g., Celery/Redis) for continuous subnet scanning, automated vector database embeddings (currently using exact and keyword retrieval fallbacks), and multi-operator human-in-the-loop qualitative clinical SOC trials are identified as future engineering roadmap items.

VI. Threats to Validity

A. Internal Validity

Ground-truth relevance ratings were assigned using CISA SSVC decision guidelines. While SSVC is an authoritative federal standard, mapping discrete decision trees into ordinal relevance grades introduces potential discretization subjectivity. To mitigate this threat, we verified all metric assertions against both a primary emergency threshold ($\tau = 3$) and an actionable threshold ($\tau = 2$). Furthermore, reference network exposure (N) and asset criticality (A) reflect standard architectural assumptions (e.g., edge gateway vs. internal server) rather than a specific organization's private telemetry.

B. External Validity

Our evaluation dataset consists of 41 real, publicly documented vulnerabilities. While diverse, $N = 41$ represents a sample size that limits claims of broad statistical generalizability across the entire NVD corpus (¿250,000 CVEs). Furthermore, EPSS probabilities model a rolling 30-day forecast and drift continuously; replicating the benchmark at a future date without using our frozen snapshot will introduce slight numerical variance.

C. Construct Validity

Absence from the CISA KEV catalog confirms only that exploitation has not been observed and cataloged by federal reporting channels; it does not guarantee that a vulnerability has never been targeted in covert or proprietary adversary operations.

VII. Conclusion

This paper presented Vulture-AI, an evidence-grounded framework for automated vulnerability analysis and prioritization. By strictly decoupling quantitative risk scoring from generative narrative assistance, Vulture-AI resolves the twin challenges of CVSS alert fatigue and LLM hallucination. The proposed Vulture Risk Score (VRS) integrates normalized CVSS severity, FIRST EPSS probabilities, CISA KEV catalog indicators, and environmental context with a deterministic tie-breaking hierarchy.

Evaluated on a benchmark of 41 real public vulnerabilities against CISA SSVC decision criteria, VRS achieved an NDCG@10 of 1.0000, Precision@10 of 1.0000 on emergency actions, and a Spearman correlation of 0.9488, substantially outperforming CVSS-only (0.7563 NDCG, 0.6000 P@10) and unweighted baselines. Ablation experiments demonstrated that environmental context accounts for a 7.1% improvement in rank correlation. Future work will extend Vulture-AI with distributed asynchronous worker queues and evaluate longitudinal SOC deployments across enterprise environments.

References

[1] National Institute of Standards and Technology, "National Vulnerability Database (NVD)," https://nvd.nist.gov/, 2026.

[2] FIRST, "Common Vulnerability Scoring System v3.1: Specification Document," Forum of Incident Response and Security Teams, Tech. Rep., 2019. [Online]. Available: https://www.first.org/cvss/v3.1/specification-document

[3] P. Mell, K. Scarfone, and S. Romanosky, "A complete guide to the common vulnerability scoring system version 2.0," *IEEE Security & Privacy*, vol. 5, no. 6, pp. 23–31, 2007.

[4] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit Prediction Scoring System (EPSS)," *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 1–17, 2021.

[5] Cybersecurity and Infrastructure Security Agency, "Binding Operational Directive 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities," https://www.cisa.gov/binding-operational-directive-22-01, 2021.

[6] ——, "Known Exploited Vulnerabilities Catalog," https://www.cisa.gov/known-exploited-vulnerabilities-catalog, 2026.

[7] J. M. Spring, E. Hatlebakke, A. Householder, A. Manion, and D. Shick, "Prioritizing Vulnerability Response with a Stakeholder-Specific Vulnerability Categorization," Software Engineering Institute, Carnegie Mellon University, Tech. Rep. CMU/SEI-2020-TR-001, 2020.

[8] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISEC)*, 2023, pp. 79–90.

[9] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W.-t. Yih, T. Rocktäschel, S. Riedel, and D. Kiela, "Retrieval-augmented generation for knowledge-intensive NLP tasks," in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, 2020, pp. 9459–9474.